

Identity & Access Management Access Review

Audit Report — Confidential

Report Classification: Confidential — For Authorized Recipients Only

Review Type: Automated Access Review — Full Population Analysis

Total Population Reviewed: 2,502 findings across all business units

Report Status: Final

Distribution: Board Audit Committee | Chief Information Security Officer | Chief Risk Officer | Chief Compliance Officer

Executive Summary

This report presents the findings of an enterprise-wide automated access review encompassing 2,502 individual findings across all organizational departments. The volume, severity distribution, and nature of these findings collectively indicate a high-risk identity and access management (IAM) posture requiring immediate executive attention and structured remediation at both the individual account and program levels.

Of the 2,502 total findings, 500 are rated Critical (20%), 89 are rated High (3.6%), and 1,913 are rated Medium (76.4%). The presence of 500 Critical-severity findings — each representing a terminated user with an active system record — is the single most consequential outcome of this review. These accounts represent former employees or contractors whose system access was not revoked upon separation, creating conditions for unauthorized access, insider threat exploitation, credential abuse, and regulatory non-compliance. In a regulated environment such as banking or healthcare, each unrevoked terminated-user account constitutes an independent control failure with potential regulatory, legal, and financial exposure.

The remaining 1,913 Medium-severity findings reflect dormant accounts with no login activity in 90 or more days. While individually rated lower in severity, the aggregate volume of dormant accounts across every department in the organization signals a systemic absence of access hygiene controls and lifecycle management processes.

The 89 High-severity findings — comprising contractors with privileged access and privileged users with no assigned manager — represent elevated risk due to the combination of elevated permissions and reduced supervisory oversight.

No department is unaffected. Findings span Finance, Legal, Audit, IT, HR, Engineering, Operations, Treasury, Marketing, Sales, Compliance, and Executive leadership functions. The concentration of findings in Finance

(224), Legal (223), and Audit (219) is particularly significant, as these departments handle the organization's most sensitive financial, legal, and oversight data. The presence of Critical findings within the Executive department — including accounts attributed to roles such as Manager, Developer, and Analyst — warrants heightened scrutiny.

The overall risk posture of this organization's IAM program is assessed as materially deficient. The findings are not isolated anomalies; they represent the output of systemic process failures in joiner-mover-leaver (JML) workflows, access certification, privileged access governance, and account lifecycle management. Remediation must be pursued urgently at the individual account level and structurally at the program level.

Thematic Risk Analysis

2.1 Dominant Finding Type: Terminated Users with Active System Records (Critical — 500 findings)

The single largest Critical-severity finding category — terminated users retaining active system records — accounts for 100% of all Critical findings and represents 20% of the total finding population. This concentration is not a data anomaly; it is evidence of a broken or absent offboarding control.

In a mature IAM environment, user account deprovisioning is triggered automatically upon HR system termination events, with accounts disabled within hours and formally deprovisioned within a defined window (typically 24–72 hours per industry standards). The existence of 500 such accounts across every department in the organization suggests that no reliable automated linkage exists between the HR system of record and the identity governance platform. Provisioning and deprovisioning appear to be manual, ad hoc, or insufficiently monitored.

The risk posed by these accounts is not theoretical. Terminated users may retain knowledge of credentials, and their accounts — if not disabled — represent exploitable entry points for unauthorized access, whether by the former user, a malicious external actor who has obtained credentials, or an internal party leveraging the account for privilege escalation or data exfiltration. In regulated industries, these accounts also create direct audit findings under separation-of-duties and access control requirements across multiple frameworks.

Of particular concern are the six terminated accounts identified with Privileged access levels: `jwilson6416`, `tjohnson6257`, `jlopez6103`, `jwilson7263`, `rsingh7058`, `pnguyen7030`, and `ajohnson6835`. Privileged accounts belonging to terminated users represent an exponentially higher risk, as these accounts may have administrative, SysAdmin, or elevated system rights that could facilitate widespread unauthorized activity.

Additionally, several terminated accounts carry sensitive organizational roles — including Director, VP, SysAdmin, and Manager — within departments such as IT, Legal, Treasury, Engineering, and Executive functions. The combination of seniority, likely broad access scope, and unrevoked status compounds the risk profile of these specific accounts.

2.2 Secondary Finding Type: Dormant Accounts (Medium — 1,913 findings)

Dormant accounts — those with no recorded login activity in 90 or more days — constitute 76.4% of all findings and represent the largest finding category by volume. While each is individually rated Medium severity, the aggregate pattern indicates an organization-wide absence of access recertification controls.

Dormant accounts are a persistent and well-documented attack surface. Unused credentials are less likely to be monitored for anomalous activity, are frequently excluded from password rotation policies, and may retain access rights that have become excessive relative to the user's current role. In environments where role drift or internal transfers occur without corresponding access updates, dormant accounts may hold legacy permissions that no longer reflect the principle of least privilege.

The distribution of dormant accounts across all departments — with no organizational unit below 191 findings — confirms that this is not a departmental failure but an enterprise-level control gap. The absence of an automated dormancy detection and response process is the root cause. In a mature program, accounts inactive beyond a defined threshold (typically 30–90 days depending on regulatory environment) are automatically flagged, reviewed, and either recertified or disabled.

2.3 High-Severity Findings: Privileged Access Without Adequate Oversight (High — 89 findings)

The 89 High-severity findings break into two sub-categories: contractors with privileged access (70 findings) and privileged users with no manager assigned (19 findings).

Contractors with privileged access represent a well-established control failure pattern. Third-party personnel, by their nature, operate outside the organization's standard HR lifecycle controls, yet these 70 individuals have been granted elevated system permissions. Contractor access should, as a baseline control, be time-limited, scoped to minimum necessary permissions, and subject to enhanced review cycles. The presence of 70 contractors with privileged access — absent evidence of compensating controls — suggests that privileged access provisioning processes do not adequately distinguish between permanent staff and third-party personnel.

The 19 privileged users with no manager assigned represent a governance gap in supervisory oversight. Manager assignment is a foundational requirement for access recertification workflows: without a designated manager, these accounts cannot be subjected to periodic review, approval, or challenge. This creates a structural blind spot in the access certification process, as these accounts may be perpetually excluded from recertification cycles due to an unresolvable workflow dependency.

2.4 Departmental Risk Concentration

The top five departments by finding count — Finance (224), Legal (223), Audit (219), IT (218), and HR (216) — are precisely the departments that handle the organization's most sensitive and regulated data categories. This concentration warrants specific commentary:

- Finance and Treasury (432 combined findings): These departments handle financial reporting, payment processing, and treasury operations. Unauthorized or unreviewed access in these areas creates direct exposure to financial fraud, insider threat, and regulatory violations under SOX, PCI-DSS, and applicable banking regulations. The presence of terminated Finance analysts and a Treasury SysAdmin with active records is particularly acute.
- Legal (223 findings): Legal department systems typically contain privileged communications, litigation strategy, regulatory correspondence, and M&A-sensitive; information. Unrevoked access to former Legal personnel — including a terminated Director — poses significant attorney-client privilege and data confidentiality risks.
- Audit (219 findings): The concentration of findings within the Audit department itself is an independence and integrity concern. An organization's internal audit function should model exemplary access hygiene. Findings within this department undermine the credibility of internal oversight functions and should be escalated to the Audit Committee directly.
- IT (218 findings): IT department accounts frequently carry broader system access than business users. Three terminated IT analysts and a Developer with active records, combined with dormant IT accounts, represent a significant technical risk vector.
- HR (216 findings): HR systems contain personally identifiable information (PII), compensation data, disciplinary records, and — critically — the very offboarding records that should trigger access deprovisioning. Access control failures in HR create a recursive risk: if HR system access is not properly governed, the integrity of the offboarding process itself may be compromised.

2.5 Severity Distribution and Control Maturity Assessment

The severity distribution of findings — heavily weighted toward Critical and Medium, with a comparatively small High population — is diagnostically informative. The near-absence of a proportional High-severity finding population relative to Critical and Medium suggests that the organization's access review has surfaced two distinct failure modes operating simultaneously: acute failures (terminated users, Critical) and chronic failures (dormant accounts, Medium). The smaller High population reflects point-in-time governance gaps rather than systemic process failures of equivalent scale.

From a control maturity perspective, the aggregate findings are consistent with a Level 1–2 (Initial/Developing) IAM maturity profile on standard capability models. Controls exist in concept but are not systematically enforced, automated, or consistently applied across the enterprise. Remediation at this scale requires not only account-level action but a fundamental uplift of IAM program infrastructure.

Priority Findings Detail

The following 50 findings represent the highest-priority subset of the total finding population, selected for individual analysis based on severity rating and risk profile. All are rated Critical. Findings involving Privileged access level accounts are noted and should be treated as the highest priority subset within this section.

FINDING: [Critical] — randerson13

Department: Legal | Role: Manager | Access Level: Standard

RISK: A terminated Legal Manager retains an active system record, providing a potential unauthorized access path into legal department systems containing privileged communications, litigation materials, and regulatory correspondence. Former managers frequently hold broad access permissions commensurate with supervisory functions, amplifying the scope of potential exposure. This finding may also constitute a violation of data protection and access control requirements applicable to legal information governance.

REMEDIATION: Immediately disable the account and revoke all associated access tokens, sessions, and credentials within 24 hours. Conduct a post-termination access log review covering the 90 days prior to and following the identified termination date to detect any unauthorized access activity. Formally decommission the account within 5 business days following initial disable action.

FRAMEWORKS: NIST 800-53: AC-2(3), AC-2(4), PS-4 | PCI-DSS: Requirement 7.3.1, 8.2.6 | SOC 2: CC6.2, CC6.3 | HIPAA: §164.312(a)(2)(i) | COSO: Control Environment, Control Activities | COBIT: DSS05.04, APO01.03 | DORA: Art. 9 ICT Access Controls

FINDING: [Critical] — jsmith6492

Department: Finance | Role: Manager | Access Level: Standard

RISK: A terminated Finance Manager holds an active system record, creating unauthorized access exposure to financial systems, reporting tools, and potentially sensitive budget or forecasting data. Managerial roles in Finance typically carry approval rights and elevated data access that extend beyond individual contributor permissions. In a regulated banking or financial services environment, this represents a direct control failure under financial data access governance requirements.

REMEDIATION: Disable account and revoke all associated credentials and session tokens within 24 hours. Perform a retrospective access log review to determine whether any system activity occurred following the recorded termination date. Complete full account deprovisioning within 5 business days and document remediation actions in the access review log.

FRAMEWORKS: NIST 800-53: AC-2(3), PS-4, AU-2 | PCI-DSS: Requirement 8.2.6, 7.3.1 | SOC 2: CC6.2, CC6.3 | HIPAA: §164.312(a)(2)(i) | COSO: Control Activities, Risk Assessment | COBIT: DSS05.04, MEA02.01 | DORA: Art. 9

FINDING: [Critical] — mnguyen6489

Department: Compliance | Role: Specialist | Access Level: Standard

RISK: A terminated Compliance Specialist retains an active system record, presenting unauthorized access risk to compliance monitoring systems, regulatory reporting tools, and audit-sensitive data. Compliance personnel routinely access information pertaining to regulatory filings, internal investigations, and control testing — categories of information that carry significant confidentiality obligations. Unauthorized retention of this access post-termination also creates a meta-compliance risk: a compliance function with demonstrable access control failures is materially weakened in its regulatory standing.

REMEDIATION: Disable account within 24 hours. Review system access logs for any post-termination activity and escalate findings to the Chief Compliance Officer if activity is detected. Complete full deprovisioning within 5 business days and notify relevant regulators if post-termination data access is confirmed.

FRAMEWORKS: NIST 800-53: AC-2(3), PS-4, IR-6 | PCI-DSS: Requirement 8.2.6 | SOC 2: CC6.2, CC6.3, CC7.2 | HIPAA: §164.312(a)(2)(i), §164.308(a)(1) | COSO: Monitoring Activities | COBIT: DSS05.04, APO13.01 | DORA: Art. 9

FINDING: [Critical] — wmiller6481

Department: Operations | Role: Developer | Access Level: Standard

RISK: A terminated Operations Developer retains an active system record, posing a risk of unauthorized access to operational systems, application codebases, or deployment pipelines. Developer access frequently includes the ability to read, modify, or deploy system components, creating potential for data exfiltration, code tampering, or introduction of malicious logic if exploited. Operations systems may also interface with production environments, amplifying the potential impact.

REMEDIATION: Disable account and revoke all code repository, deployment tool, and API access within 24 hours. Review version control and deployment logs for anomalous activity attributable to this account post-termination. Complete full deprovisioning within 5 business days.

FRAMEWORKS: NIST 800-53: AC-2(3), CM-5, PS-4 | PCI-DSS: Requirement 8.2.6, 6.3.3 | SOC 2: CC6.2, CC8.1 | HIPAA: §164.312(a)(2)(i) | COSO: Control Activities | COBIT: DSS05.04, BAI06.01 | DORA: Art. 9

FINDING: [Critical] — jtaylor6466

Department: Marketing | Role: Coordinator | Access Level: Standard

RISK: A terminated Marketing Coordinator retains an active system record, exposing marketing platforms, customer data repositories, and campaign management tools to potential unauthorized access. Marketing systems frequently contain customer PII, consent records, and segmentation data subject to privacy regulations including GDPR and CCPA. Unrevoked access by a former employee in this context creates both a security and

privacy compliance exposure.

REMEDIATION: Disable account within 24 hours. Review access logs for any post-termination activity involving customer data or marketing platforms. Complete full deprovisioning within 5 business days and notify the Privacy Officer if customer PII access is confirmed post-termination.

FRAMEWORKS: NIST 800-53: AC-2(3), PS-4, PT-2 | PCI-DSS: Requirement 8.2.6 | SOC 2: CC6.2, CC6.3 | HIPAA: §164.312(a)(2)(i) | COSO: Control Activities | COBIT: DSS05.04, APO01.03 | DORA: Art. 9

FINDING: [Critical] — lgonzalez6435

Department: Operations | Role: Analyst | Access Level: Standard

RISK: A terminated Operations Analyst retains an active system record, creating unauthorized access exposure to operational data, process management systems, and potentially production monitoring tools. Analyst access in operations environments may include read access to transaction logs, operational metrics, and system configurations that could be leveraged for reconnaissance or competitive intelligence. This finding represents a failure of the offboarding workflow specific to the Operations department.

REMEDIATION: Disable account within 24 hours. Review